

产品与技术方案草稿 · 待确认后实施

用户与权限 管理方案

为 LinkFlow 补齐用户管理、角色权限和后台操作边界，先统一规则，再进入页面、Server Actions 与 Supabase RLS 实现。

2

首期角色：普通用户 / 管理员

4

首期后台视图与核心流程

0

本草稿阶段的业务代码改动

本稿结论

首期采用“角色 + 资源所有权”的权限模型。普通用户只能管理自己的短链接和自己的账号信息；管理员可以管理全站链接、用户状态和系统设置。权限判断必须同时存在于页面入口、服务端 Action/API 和数据库 RLS，不能只依赖前端隐藏按钮。

需要先确认的产品规则：管理员是否可以禁用用户、删除用户、重置他人密码，以及管理员是否可以修改他人链接密码。这些决定会直接影响 Supabase Auth 管理 API、审计日志和数据恢复策略。

交付范围：用户列表、用户详情、角色调整、账号启用状态、全局链接权限和最小权限矩阵。暂不包含组织/团队、多租户、自定义角色、复杂审批和细粒度 API token。

项目基线：Next.js App Router、Supabase Auth、PostgreSQL RLS、现有 /dashboard 与 /admin 路由。

一、角色与账号状态

角色/状态	定义	首期行为
普通用户 user	已注册并通过认证的业务用户。	进入用户控制台；创建、查看、删除和更新自己的短链接；修改自己的登录密码。
管理员 admin	负责站点运营和数据管理的受信用户。	拥有普通用户能力；额外访问用户管理、全局链接管理和系统设置。
未登录	没有有效 Supabase session 的访问者。	按站点设置使用公开创建、公开跳转；不能访问任何用户或管理数据。
已禁用 disabled	账号仍保留数据，但暂时禁止登录和业务操作。	登录被拒绝；已有短链是否继续跳转需要产品确认。管理员仍可查看其数据。

推荐的数据拆分

auth.users 负责认证凭据和 Supabase 用户生命周期；profiles 负责业务角色、显示信息和账号状态；links 负责短链资源及所有权。密码 hash、service role key 等敏感值不能进入客户端 DTO。

建议：将当前 profiles.role 保留为首期兼容字段，新增 status、display_name、last_seen_at、created_at 和 updated_at。角色值继续限制为 user/admin，避免自由文本。

账号生命周期

- 1. 注册：Supabase Auth 创建用户，服务端可靠地创建或补齐 profile，默认 role=user、status=active。
- 2. 登录：认证成功后，服务端检查 profile 是否存在且状态为 active；禁用用户立即登出并返回统一提示。
- 3. 角色调整：仅管理员可操作；变更后重新验证目标用户的后台入口和数据访问。
- 4. 删除/停用：首期建议只提供“禁用”，保留链接和审计数据；永久删除另行设计。

二、功能权限矩阵

功能	未登录	普通用户	管理员
访问首页、公开跳转	允许	允许	允许
公开创建短链	按站点设置	允许	允许
访问用户控制台	禁止	允许	允许
创建/查看自己的链接	禁止	允许	允许
编辑/删除自己的链接	禁止	允许	允许
查看他人链接详情	禁止	禁止	允许
删除他人链接	禁止	禁止	允许
访问用户管理	禁止	禁止	允许
调整角色/禁用账号	禁止	禁止	待确认后允许
访问系统设置	禁止	禁止	允许
导出全站链接	禁止	禁止	允许

权限判断的三个层次

入口层 middleware 和页面加载时拦截未登录、非管理员访问，提供正确跳转。	服务层 每个 Action/API 使用 <code>requireAuth</code>、<code>requireAdmin</code>，并校验输入和资源归属。	数据层 RLS 作为最终边界。所有普通用户写操作必须带当前 <code>auth.uid()</code> 所有权条件。
---	---	--

禁止的实现方式：只在按钮上隐藏管理员功能；把全部查询切换成 service role；给 links 全表开放匿名读取；使用客户端传入的 user_id 决定资源归属。

首期拒绝规则

- 普通用户访问任意 `/admin/*` 直接返回控制台或 403，不透露后台数据。
- 普通用户提交他人的 link id、user id 或 profile id 时，服务端返回统一无权限结果。
- 管理员操作不存在或已删除资源时，返回“资源不存在”，不伪装成功。
- 禁用账号的 session 失效后，不允许通过旧页面继续写入。

三、用户管理页面

管理员入口：/admin

将当前“用户与权限 / 未开放”替换为可用入口。首页保持三个并列管理模块：全局链接、用户与权限、系统设置。管理员入口在普通用户控制台中继续显示为图标按钮，但只由真实角色决定。

用户列表：/admin/users

区域	内容	交互
页面头部	用户与权限、用户总数、返回管理控制台。	刷新、搜索框、状态/角色筛选。
用户表格	邮箱、角色、状态、注册时间、最近活跃、链接数量。	点击一行进入详情；邮箱需截断且可复制。
行操作	查看详情、调整角色、禁用/启用。	危险操作使用确认对话框；不能对当前最后一个管理员直接降权。
状态	加载、空数据、查询失败、无权限、分页。	失败可重试；空状态不冒充查询成功。

用户详情：/admin/users/[id]

左侧展示身份与状态，右侧展示该用户的短链接摘要和操作记录。默认只显示业务字段，不显示 Auth token、密码、password_hash、Turnstile secret 或其他密钥。

推荐的详情操作：调整角色、禁用/启用、查看链接。暂不提供管理员代替用户修改登录密码；若确有需求，使用 Supabase Admin API 单独实现并写审计记录。

普通用户侧的变化

- 控制台继续只展示当前用户链接；管理员可从用户详情跳转到该用户的资源过滤视图。
- 当账号被禁用或角色变化时，所有数据操作显示明确的会话/权限错误并重新加载。
- “修改链接密码”按资源所有权显示；管理员是否可修改他人链接密码列为待确认项。

四、实现边界

统一权限服务

在 `src/utils/auth.ts` 增加并统一复用：

- `requireAuth`：返回当前 Supabase 用户。
- `requireAdmin`：返回当前用户及 `profile`，角色不是 `admin` 时返回无权限。
- `requireOwner`：在资源操作前校验当前用户与资源 `user_id` 一致。
- 所有检查保留数据库查询条件，避免“先查再写”之间被绕过。

建议的 profile 字段

字段	类型	用途
id	uuid / auth.users	认证用户主键。
email	text	展示快照；真实认证邮箱以 Auth 为准。
role	enum/text check	user 或 admin。
status	enum/text check	active 或 disabled，默认 active。
created_at / updated_at	timestampz	列表排序和变更追踪。
disabled_at / disabled_by	timestampz / uuid	记录禁用来源，便于审计。

RLS 方向

- `profiles`：用户读取本人；管理员读取全部。角色和状态的更新仅允许受控服务端路径，不能开放普通用户 `update`。
- `links`：用户只读写 `auth.uid() = user_id` 的资源；管理员全局读取/删除策略使用安全的 `is_admin()`。
- `审计表`：仅服务端写入，管理员读取；不把用户输入原样写入日志。

迁移注意：当前 README 中 `profile` 初始化、RLS 策略和管理员查询存在重复/分散描述。正式实施前应生成一次性 SQL migration，并在隔离 Supabase 项目验证匿名、用户 A、用户 B、管理员四种身份。

五、验收清单与待确认项

建议的验收矩阵

身份	应可执行	应被拒绝
匿名	公开跳转；按设置公开创建。	用户列表、用户详情、后台链接、系统设置。
普通用户 A	自己的链接和账号操作。	用户 B 的链接、用户管理、管理员设置。
普通用户 B	自己的链接和账号操作。	用户 A 的链接、用户管理、管理员设置。
管理员	全局链接、用户管理、系统设置。	无效资源、非法字段、越权伪造 user_id。
禁用用户	按最终规则处理公开短链。	登录、创建、编辑、删除和任何后台写操作。

需要产品确认的 6 个问题

- 1. 管理员是否可以禁用普通用户？禁用后该用户已经创建的短链是否继续可跳转？
- 2. 管理员是否可以删除用户？首期是否只做禁用、不做永久删除？
- 3. 管理员是否可以把自己降为普通用户？最后一个管理员如何保护？
- 4. 管理员是否可以修改他人短链密码，还是只允许删除/查看？
- 5. 是否需要审计日志？至少建议记录角色变更、禁用/启用、全局删除。
- 6. 后续是否需要团队/多租户？若近期需要，profile 方案应提前避免把权限写死在 role 字段。

推荐默认答案：首期允许管理员禁用用户，不永久删除；禁用不影响已有公开短链跳转；管理员不可降权最后一个管理员；不允许管理员修改他人短链密码；记录关键管理操作；暂不做团队权限。

确认后的实施顺序

- 1 补统一权限服务与 profile migration。
- 2 实现用户列表/详情和管理员 Action。
- 3 补 RLS 与四身份权限测试。
- 4 接入后台导航、加载/失败/空状态。
- 5 运行 lint、构建和真实 Supabase 隔离环境回归。

本 PDF 是“先看规则”的草稿，不包含已执行的数据库变更，也不应直接用于生产配置。